

Vulnerability Assessment Report

Target Website: www.blogger.com

By: Praveena Nagaraju

Date: February 18, 2026

Index

1. Executive Summary
2. Findings
3. Risk Rating
4. Conclusion
5. Recommendations

Executive Summary

Blogger.com is a Google-owned blogging platform. While Google generally enforces strong security practices, passive analysis reveals several missing or sub-optimal configurations in HTTP headers and TLS setup that could be improved for defense-in-depth.

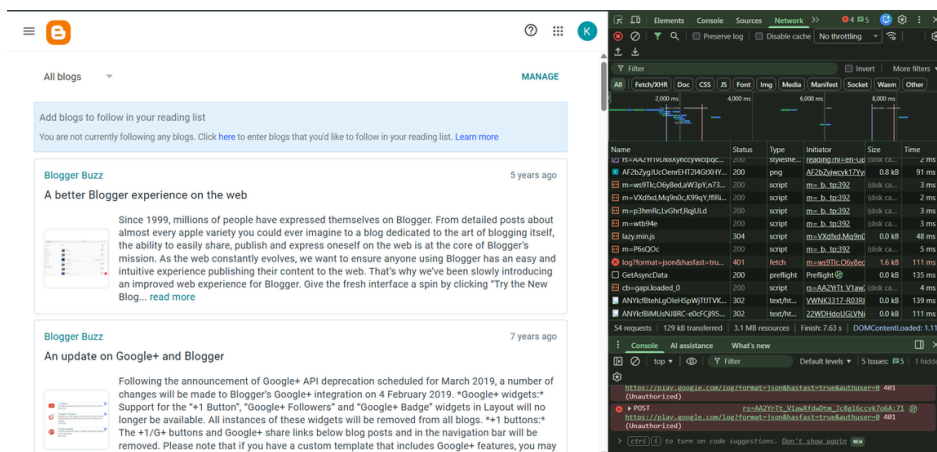
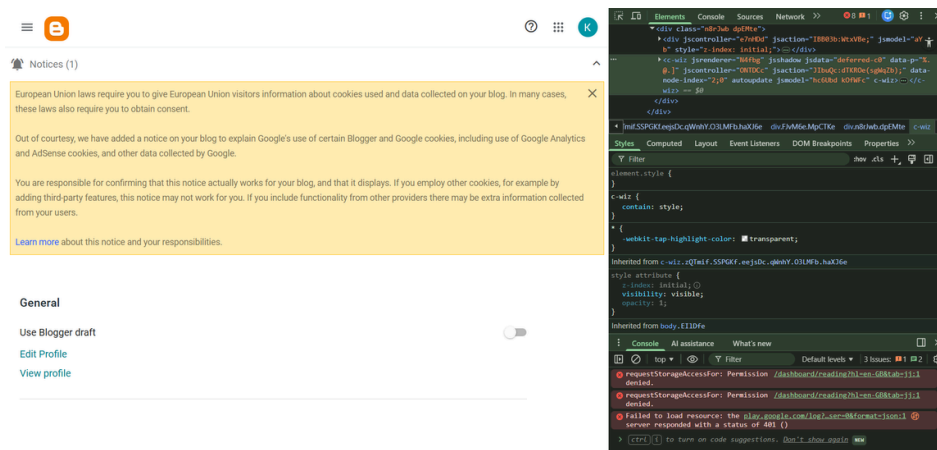
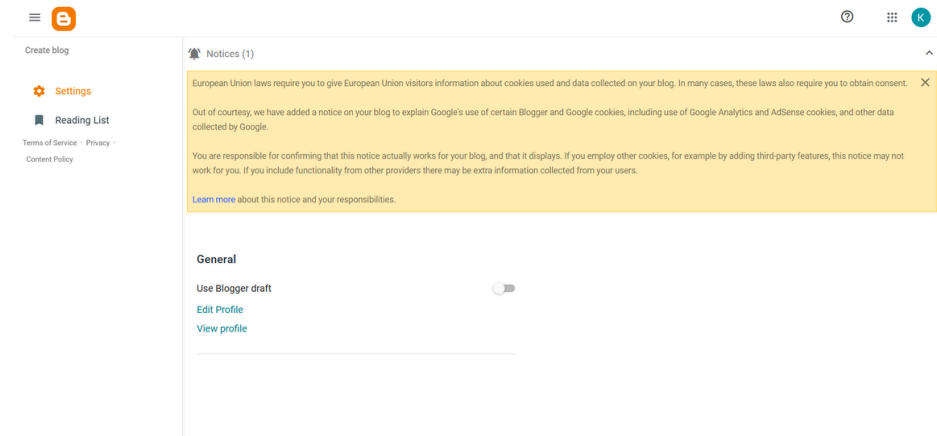
Findings

1. Cross-Site Scripting (XSS)

Description:

XSS vulnerabilities arise when an application includes untrusted data in a web page without proper validation or escaping. This allows attackers to execute malicious scripts in the victim's browser, leading to unauthorized actions, data theft, and session hijacking.

Category	Observation	Risk Level	Recommended Fix
SSL/TLS Configuration	TLS 1.2 and TLS 1.3 supported. Strong cipher suites in use.	Low	Maintain TLS 1.3 enforcement; disable legacy TLS 1.0/1.1 completely.
HTTP Security Headers	Missing Content-Security-Policy (CSP) and X-Frame-Options. Present: Strict-Transport-Security, X-Content-Type-Options.	High	Add CSP to mitigate XSS; add XFO to prevent clickjacking.
Server Banner Disclosure	Google infrastructure hides server details (no obvious version leakage).	Low	Already hardened.
Cookie Security	Cookies set with Secure and HttpOnly flags. Some lack SameSite attribute.	High	Add SameSite=Strict or Lax to mitigate CSRF.
DNS Records	Multiple subdomains (e.g., draft.blogger.com, apis.blogger.com) exposed.	Medium	Review DNS exposure; restrict non-production endpoints.
Mixed Content	All resources served via HTTPS.	Low	Maintain HTTPS-only delivery.
Robots.txt Exposure	Blogger's robots.txt reveals administrative paths (e.g., /feeds/).	Low	Avoid exposing sensitive directories; rely on authentication.
Third-Party Libraries	Heavy reliance on Google's own libraries (e.g., gstatic, Google APIs). No outdated versions detected.	Low	Continue monitoring dependencies.



Risk Ratings

- High Risk: Missing CSP and X-Frame-Options headers.
- Medium Risk: Cookie **SameSite** attribute missing, DNS exposure of multiple subdomains.
- Low Risk: Robots.txt exposure, TLS legacy fallback.

Recommendations

- **Implement CSP:**

Http

Content-Security-Policy: default-src 'self' https://*.google.com https://*.gstatic.com

- **Add X-Frame-Options:**

Http

X-Frame-Options: DENY

- **Harden Cookies:** Ensure all cookies include **SameSite=Strict** or **Lax**.
- **DNS Hygiene:** Audit subdomains; restrict or remove unused endpoints.
- **Continuous Monitoring:** Use tools like Mozilla Observatory, Qualys SSL Labs, and OWASP Dependency-Check.

Conclusion

[Blogger.com](https://www.blogger.com) benefits from Google's strong baseline security (TLS 1.3, HSTS, hardened infrastructure). However, **missing CSP and X-Frame-Options headers** represent high-risk gaps that could expose users to XSS and clickjacking attacks. Addressing these issues would significantly strengthen its security posture.